

Mapeo de Preguntas de la Encuesta MITRE ATT&CK a Requisitos Normativos / Marcos

Nota: MITRE ATT&CK no es una norma de cumplimiento, pero se alinea y complementa con marcos de riesgo y regulación (NIST CSF, ISO 27001, ENS, DORA, NIS2, etc.).[web:66][web:52]

ID Pregunta	Tema principal	ATT&CK / Concepto	Marcos / Normativa relacionada (ejemplos)
G1	Conocimiento y respaldo directivo	Uso estratégico ATT&CK	NIST CSF Govern (GV.OC, GV.RR), ISO 27001 liderazgo, ENS organización
G2	Política formal ATT&CK	Política de detección	NIST CSF Govern (GV.PO), ISO 27001 A.5, ENS marco orgánico
G3	Priorización de casos de uso	ATT&CK-driven use-cases	NIST CSF Detect (DE.AE), ISO 27001 A.8, DORA gestión de riesgos TI
G4	Reporting de cobertura a dirección	KPIs de cobertura	NIST CSF Govern (GV.ME), ENS informes de seguridad
C1	Inventario de tácticas cubiertas	Cobertura táctica	NIST CSF Detect (DE.AE), ISO 27001 A.8, NIS2 capacidades operativas
C2	% tácticas cubiertas	Métrica de cobertura	NIST CSF Detect, ENISA Threat Landscape – mapping TTP[web:66] [web:43]
C3	% técnicas cubiertas	Métrica técnica	NIST CSF Detect, NIS2 capacidades, DORA resiliencia operativa
C4	Ejercicios de validación (purple team, etc.)	Validación de cobertura	NIST CSF Respond (RS.TE), ISO 27001 A.5.29, ENS medidas de operación
C5	Uso de evaluaciones MITRE de proveedores	Selección de tecnología	NIST CSF Protect/Detect, ISO 27036, DORA/supply chain TI[web:16] [web:22]
C6	Gap cobertura declarada vs real	Gestión de brechas	NIST CSF Govern (GV.RM), ISO 27001 mejora, ENS revisión
Q1	Calidad de detecciones	Alertas y ruido	NIST CSF Detect (DE.CM), ISO 27001 A.8.16
Q2	Métrica de falsos positivos	Calidad y tuning	NIST CSF Detect, Gestión de calidad de controles

Q3	Racionalización de reglas	Optimización detección	NIST CSF Detect, mejora continua
Q4	% alertas etiquetadas ATT&CK	Contextualización	NIST CSF Detect, ISO 27035 gestión de incidentes
T1	MTTD mapeado a ATT&CK	Métrica temporal	NIST CSF Detect/Respond, NIS2 tiempos de respuesta
T2	MTTC/MTTR en cadenas ATT&CK	Respuesta y recuperación	NIST CSF Respond/Recover, DORA continuidad
T3	Uso de tiempos para inversiones	Riesgo y ROI	NIST CSF Govern, NIS2 gestión de riesgos
A1	CTI con ATT&CK	Inteligencia de amenazas	NIST CSF Detect (DE.CM, DE.AE), ENISA amenazas sectoriales[web:66][web:43]
A2	Priorización según ENISA / panorama europeo	Alineación UE	ENISA Threat Landscape, NIS2, marcos nacionales
A3	Mapeo de incidentes a ATT&CK	Lecciones aprendidas	NIST CSF Respond (RS.AN), ISO 27035
A4	Tácticas frecuentes en incidentes	Estadística TTP	NIST CSF Detect/Respond, ENISA ETL[web:66][web:63]
I1	Herramientas con soporte nativo ATT&CK	Integración tecnológica	NIST CSF Protect/Detect, DORA arquitectura TI
I2	Dashboards / heatmaps ATT&CK	Visualización de riesgos	NIST CSF Govern/Detect, reporting ENS
I3	Proceso de actualización con nuevas versiones	Gestión de cambios	NIST CSF Govern/Protect, ISO 27001 A.8.32
E1	Red/purple teaming con ATT&CK	Pruebas avanzadas	NIST CSF Respond (RS.TE), ENS ejercicios
E2	Actualización de métricas tras ejercicios	Mejora continua	NIST CSF Govern (GV.ME), ISO 27001 mejora
E3	Objetivos de mejora vinculados a ATT&CK	KPIs de equipos	NIST CSF Govern, gestión de rendimiento
F1	Presupuesto ATT&CK-oriented	Inversión en capacidad	NIST CSF Govern, DORA, NIS2 financiación de ciberseguridad

F2	IGM basado en ATT&CK	Índice de madurez	NIST CSF Govern, modelos de madurez
F3	ROI de iniciativas ATT&CK	Economía de ciberseguridad	NIST CSF Govern, DORA
H1	Formación en ATT&CK	Capacidades humanas	NIST CSF Govern (GV.RR), ISO 27001 A.6, ENS formación
H2	Uso de ATT&CK en comunicación	Lenguaje común	NIST CSF Govern, cultura de seguridad
H3	Roles responsables de ATT&CK	Gobierno de la detección	NIST CSF Govern, ENS roles y responsabilidades